

Red Lion Controls Firmware Attack Surface & Detection Brief

Scope: Research-only — firmware extraction is pending; no `firmware-staging/Red-Lion/` rootfs yet, no hash catalog. Six product lines (Graphite G09/G10/G12/G15, G3-Series HMI, CR3000/CR1000, Sixnet IndustrialPro RTU SN/EM, DA-50N Industrial Gateway, Crimson 3.1/3.2 design suite) across three architecture classes prime the analyst queue for the moment firmware lands. Findings combine CISA ICS advisories, NVD CVE pages, Red Lion PSIRT bulletins, vendor docs, and named research labs (Claroty Team82, Dragos, Forescout Vedere Labs) — *not* direct rootfs observation. Treat every claim as research-anchored; replace with extracted-firmware evidence once the queue advances.

Purdue layer mapping: Graphite, G3, and CR3000/CR1000 HMI panels (Group A) live at **Purdue L2 (Area Supervisory)** as the pump-house / lift-station operator console; Sixnet IndustrialPro RTU and DA-50N gateway (Group B) live at **Purdue L1 (Basic Controllers)** — the Sixnet RTU runs ladder/IEC-61131 control logic in modified Linux and is the cellular-backhailed remote endpoint; Crimson 3.1/3.2 design suite (Group C) runs at **Purdue L3 (Site Operations)** on the integrator EWS laptop, with the cloud sync/update channel touching **Purdue L3.5 (IT/OT Boundary)**. See [purdue-l1-basic-controllers-brief.md](#), [purdue-l2-area-supervisory-brief.md](#), [purdue-l3-site-operations-brief.md](#), and [purdue-l35-it-ot-boundary-brief.md](#) for the cross-vendor views.

Architecture grouping (drives the threat model, not the SKU)

Class	Purdue layer	Products	Stack	Catalog depth
A. Crimson HMI panels	L2 Area Supervisory	Graphite G09/G10/G12/G15, G3-Series, CR3000, CR1000	Crimson 3.x runtime on ARM/Cortex; embedded web UI, FTP, VNC server, J1939/Modbus/EtherNet-IP/DNP3 drivers; <code>.cd3</code> / <code>.cd31</code> project files	research-only (pending extraction)
B. Sixnet RTU + DA-50N gateway	L1 Basic Controllers	Sixnet IndustrialPro SN/EM Series (SN-6000/6500/6600, EM Series), DA-50N	Modified Linux (older 2.6/3.x kernel + older OpenSSL); DNP3 + Modbus + IEC 60870-5; legacy proprietary "Sixnet protocol" on UDP/1594; cellular/serial backhaul; SSH/Telnet	research-only

Class	Purdue layer	Products	Stack	Catalog depth
C. Crimson design suite	L3 Site Operations (cloud sync → L3.5)	Crimson 3.1, Crimson 3.2	Windows .NET app; project files .cd3 / .cd31 carry firmware-download targets + tag DB + credentials; cloud sync to Red Lion device-cloud	research-only

Group A — Crimson HMI panels (Graphite / G3 / CR) — Purdue L2 (Area Supervisory)

Direct attack surface (Crimson 3.x runtime per vendor docs + CISA ICS advisory cluster):

```
HTTP/HTTPS web UI (default admin/123456 on most models) • FTP server (firmware/project push) •  
VNC server (TCP/5900 – frequently default-no-password) • SNMPv1/v2c • Modbus TCP/502 •  
EtherNet/IP TCP/44818 • DNP3 TCP/20000 • J1939 • proprietary Crimson sync/download port
```

Vendor documentation and CISA ICS advisories confirm the project-download channel accepts authenticated *and* unauthenticated config exposure on affected Crimson 3.0/3.1/3.2 builds — the web UI leaks configuration without enforcing auth on certain endpoints. Default `admin / 123456` is baked into factory state on Graphite, G3, and CR panels.

Confirmed advisories:

Advisory	Product	Vector	Status
CISA ICS Advisories — Red Lion family feed	Crimson 3.0/3.1/3.2 / Graphite / G3 / CR	Unauthenticated config exposure cluster on HMI runtime/web UI; default-credential class	Authoritative advisory feed — verify per firmware version once extracted
Red Lion PSIRT portal	Graphite / G3 / CR HMI family	Default-credential + web UI advisories class	Vendor PSIRT — research reference until firmware extracted
Forescout Vedere Labs — OT:ICEFALL Crimson coverage	Crimson 3.x runtime	Insecure-by-design class (auth/firmware-update/protocol) — same pattern as the OT:ICEFALL bundle	Research reference

Top attack vector (MITRE ATT&CK ICS): [T0812 Default Credentials](#) chained into [T0836 Modify Parameter](#) via the Crimson web UI — `admin/123456` plus the config-exposure class documented in CISA Red Lion advisories is single-packet HMI takeover on factory-state panels.

Group B — Sixnet IndustrialPro RTU + DA-50N gateway — Purdue L1 (Basic Controllers)

Direct attack surface (per vendor docs + Red Lion PSIRT Sixnet protocol advisories):

```
SSH/Telnet (modified Linux shell) • HTTP/HTTPS web UI • DNP3 TCP/20000 • Modbus TCP/502 •  
IEC 60870-5-104 TCP/2404 • legacy "Sixnet protocol" UDP/1594 (long-standing pre-auth concern) •  
SNMPv1/v2c • cellular (NAT'd 3G/4G/LTE – operator APN often the only perimeter) • serial passthrough
```

Vendor docs describe the Sixnet RTU as running a *modified* Linux distribution — older kernel, older OpenSSL, no signed firmware on the historical SN-6000 line. The DA-50N gateway shares the protocol-converter codebase. The legacy Sixnet protocol on UDP/1594 is the long-standing pre-auth concern.

Vendor advisories / references:

Reference	Product	Vector	Status
Red Lion PSIRT portal — Sixnet advisories	Sixnet RTU family (SN-series)	Pre-auth / auth-bypass concerns on legacy Sixnet protocol (UDP/1594); command-handling weaknesses	Verify catalog floor once firmware extracted
Red Lion PSIRT — Sixnet SN-series cleartext-transmission advisory class	Sixnet SN-series RTU	Cleartext transmission of sensitive information (credentials/control data) over cellular backhaul	Cellular-backhaul-exposed deployments at highest risk
CISA ICS Advisories index — Red Lion family	Red Lion family	Authoritative advisory feed	Reference

Top attack vector (MITRE ATT&CK ICS): [T0866 Exploitation of Remote Services](#) over the Sixnet UDP/1594 protocol → [T0855 Unauthorized Command Message](#) to write DNP3 control points on downstream pump/valve actuators. Cellular backhaul means the attack surface is reachable from the carrier APN, not just the SCADA WAN.

Group C — Crimson 3.1/3.2 design suite (Windows-side EWS) — Purdue L3 (Site Operations)

The integrator laptop running Crimson is the supply-chain pivot — identical pattern to Studio 5000 (Rockwell), TIA Portal (Siemens), and the Claroty Team82 "Evil-PLC" research. `.cd3` / `.cd31` project

files carry the firmware-download manifest, tag DB, embedded credentials, and the target device list for every panel and RTU in that integrator's fleet.

Attack vectors:

- **Project-file weaponization (Evil-PLC class).** A tampered `.cd31` opened by an integrator pushes attacker-controlled firmware/config to every Graphite/G3/CR panel it touches. See [Claroty Team82 — Evil PLC research](#).
- **Cloud sync / device-cloud channel.** Crimson 3.2 introduced cloud device management — the L3↔L3.5 sync channel is the integrator-laptop foothold path into hundreds of customer sites at once.
- **Credential reuse in `.cd3` / `.cd31`.** Project files historically embed device credentials in cleartext / weak-obfuscation; integrator-laptop disk image = whole-fleet credential dump.
- **IDE-specific advisories** — track via the [Red Lion PSIRT portal](#) and the [CISA ICS Advisories Red Lion feed](#) which covers the Crimson runtime side.

Top attack vector (MITRE ATT&CK ICS): [T0843 Program Download](#) on the integrator EWS pushing tampered project payloads → [T0857 System Firmware](#) on every panel in the fleet. The integrator laptop is the single-host blast-radius multiplier.

Water-utility deployment pattern (primary use case)

The canonical Red Lion water/wastewater stack is **Graphite G09/G10 + Sixnet IndustrialPro RTU** with **Crimson 3.x on the integrator laptop**. Graphite sits in the pump-house as the operator HMI on the L2 supervisory plane; the Sixnet RTU sits at remote reservoirs / lift stations / wellhead skids, backhauling DNP3 + Modbus (occasionally IEC 60870-5-104) over cellular or licensed radio to the central SCADA. The DA-50N appears as a protocol-converter where legacy Modbus-RTU meters or serial flow computers need to be bridged into DNP3/EtherNet/IP. Crimson runs on the system-integrator laptop — that laptop is the **single highest-value target** in the deployment: compromising it yields project files (`.cd3` / `.cd31`) carrying credentials, firmware-push targets, and the tag DB for every panel and RTU in the integrator's customer book. This is the same supply-chain pivot pattern as Studio 5000 / TIA Portal Evil-PLC ([Claroty Team82](#)) and is the realistic attack path for a state-level adversary going after municipal water at scale.

Logging matrix (highest priority)

Top 8 — ordered by detection value per ingest dollar:

#	Source	Event	What it catches	MITRE ATT&CK ICS
1	Graphite/G3/CR web UI access log	HTTP <code>POST /login</code> success following repeated 401s; first-time <code>admin</code> login from non-mgmt IP	Default-credential brute on <code>admin/123456</code>	T0812 Default Credentials
2	HMI syslog	<code>firmware.upload</code> / <code>project.download</code> outside change-window; Crimson project version mismatch on next boot	Tampered <code>.cd3</code> / <code>.cd31</code> push	T0857 System Firmware
3	Network IDS (Suricata/Zeek)	Inbound UDP/1594 (Sixnet legacy protocol) from any non-Sixnet-management source	Legacy Sixnet-protocol exploit traffic	T0866 Exploitation of Remote Services
4	Network IDS	DNP3 function codes 3/4/5/6 (Select/Operate/Direct-Operate) crossing SCADA→RTU from a non-master IP	Unauthorized control of pumps/valves via Sixnet RTU	T0855 Unauthorized Command Message
5	Network IDS	Modbus function codes 5/6/15/16 (write coils/registers) targeting Graphite/G3/CR/DA-50N from non-EWS source	HMI/gateway parameter tamper	T0836 Modify Parameter
6	Network IDS	VNC (TCP/5900) connection to a Graphite/G3 panel with no auth handshake	Default-no-password VNC takeover yielding view-manipulation	T0832 Manipulation of View
7	Sysmon on integrator EWS	EventID 11 (FileCreate) of <code>*.cd3</code> / <code>*.cd31</code> outside the integrator's project tree; EventID 1 where <code>Crimson*.exe</code> spawns <code>cmd.exe</code> / <code>powershell.exe</code> / <code>rundll32.exe</code>	Evil-PLC class project-file weaponization	T0843 Program Download
8	Cellular gateway / carrier APN log	New inbound flow from internet-facing peer to Sixnet RTU public IP on TCP/20000 (DNP3) or UDP/1594	RTU directly exposed via cellular APN misconfig	T0866 Exploitation of Remote Services

Secondary:

- Red Lion HMI audit log: enable Crimson's built-in event log (`System` → `Security` → `Audit`) and forward via syslog — categories `Auth`, `Config`, `Project-Download`, `Firmware-Update`.
- Sixnet RTU `/var/log/messages` (modified Linux) — forward via syslog where the older syslogd supports it; flag `dropbear` / `sshd` auth events and `init.d` script changes.

- Firewall: any egress from HMI/RTU VLANs to non-RFC1918; cellular-backhaul Sixnet RTUs should only egress to the SCADA poll-master IPs.
 - OT-native anomaly signals: pump start/stop or valve actuation outside the SCADA poll-master's command pattern; unexpected DNP3 `class 0` integrity poll from non-master; flow/level setpoint drift on a normally stable process loop.
-

Specific zero-day-ish concerns for your dataset

1. **Sixnet legacy protocol on UDP/1594 is a single-packet pre-auth surface.** Until firmware lands and you can map a build-number floor, treat every Sixnet IndustrialPro RTU reachable on the SCADA WAN — or worse, the cellular APN — as exploitable per the [Red Lion PSIRT Sixnet advisory class](#). Suricata rule on UDP/1594 from non-allowlisted sources is the cheapest high-signal detection in the entire brief.
 2. **Crimson `admin/123456` factory default on Graphite/G3/CR.** The CISA Red Lion advisory feed has documented the unauthenticated config-exposure cluster on top of this — combined with the default cred, a single HTTP request is whole-panel takeover. Audit every Red Lion HMI on the SCADA LAN for this credential before the firmware extraction even begins.
 3. **Evil-PLC supply-chain pivot via Crimson `.cd31` project files.** The integrator's laptop is the highest-value target in the deployment. Hash-watchlist every `.cd3` / `.cd31` file on integrator EWS hosts and alert on out-of-band modification; Claroty Team82's Evil-PLC class is directly applicable.
 4. **Sixnet modified Linux + older OpenSSL = legacy CVE chain.** Once firmware extracts, expect a long tail of inherited OpenSSL / kernel / BusyBox CVEs the vendor never backported — the same pattern Forescout Vedere Labs documented across the OT:ICEFALL bundle. Plan for an OpenSSL/kernel version-string sweep as the first post-extraction analyst task.
 5. **Cleartext transmission on Sixnet SN-series cellular backhaul.** Per the Red Lion PSIRT Sixnet advisory class, credentials and control data have traversed the cellular backhaul in cleartext on affected builds — assume any RTU not on a private APN or IPsec tunnel has had its operator credentials harvested.
-

Sources

- [CISA ICS Advisories index — Red Lion family](#)
- [Red Lion PSIRT portal](#)
- [Claroty Team82 — research index](#)
- [Claroty Team82 — Evil PLC Attack: Weaponizing PLCs](#)
- [Dragos — Threat Intelligence blog \(water-sector ICS\)](#)
- [Forescout Vedere Labs — OT:ICEFALL](#)

- [Forescout 2025 OT Threat Report — DNP3 / Modbus targeting trends](#)
- [MITRE ATT&CK for ICS — T0812 Default Credentials](#)
- [MITRE ATT&CK for ICS — T0832 Manipulation of View](#)
- [MITRE ATT&CK for ICS — T0836 Modify Parameter](#)
- [MITRE ATT&CK for ICS — T0843 Program Download](#)
- [MITRE ATT&CK for ICS — T0855 Unauthorized Command Message](#)
- [MITRE ATT&CK for ICS — T0857 System Firmware](#)
- [MITRE ATT&CK for ICS — T0866 Exploitation of Remote Services](#)
- [CISA/NSA/FBI/ASD — Best Practices for Event Logging and Threat Detection \(2024\)](#)